

Protocolo de comunicación de incidentes a clientes

Fecha 02/02/26

Divier Jácamo Álvarez

Parque metropolitano la libertad

Introducción

En este caso desarrollare un protocolo de comunicación a clientes ante algún incidente en la organización debe haber algo llamado transparencia técnica protegiendo las privacidades de dichos pacientes al no comunicarles dichos incidentes o encubrirlos a los clientes podría repercutir a una demanda por la violación de sus derechos y a procedimientos legales hacia la organización

A continuación se detallan los pasos principales del protocolo

1. Descubrimiento y clasificación

Identifique el alcance y determine inmediatamente si el ataque comprometió la confidencialidad de los datos la integridad o la disponibilidad.

Evaluar el riesgo: En salud mental, cualquier violación se considera de alto riesgo debido a la naturaleza de los datos.

2. Aviso a las autoridades

Aunque la Ley 8968 no tiene un límite de tiempo las disposiciones de la Ley 8968 y las buenas prácticas exigen actuar con rapidez.

¿A quién?: comunicarse con la PRODHAB

¿Qué reportar?: Tipo de incidente, categorías de datos afectados y acciones correctivas tomadas.

3. Comunicación con clientes

Según el principio de autodeterminación informada, los pacientes tienen derecho a saber qué sucede con su información.

Plazo: Debe ser inmediato si el incidente puede afectar a sus derechos por ejemplo el chantaje con datos clínicos

Qué pasó explica que hubo un acceso no autorizado.

Qué datos se vieron afectados: como nombres, diagnósticos, historial de citas

Qué deben hacer: se debe cambiar contraseñas si usan el portal del paciente tener cuidado con correos electrónicos sospechosos

4. Apoyo del CSIRT Nacional

Como PYME, puede buscar orientación técnica y reportar un incidente al CSIRT de Costa Rica para ayudar a prevenir ataques similares en la industria de la salud

Ahora hare un prototipo de bitácora de incidentes de como seria documentado y que lo use en un futuro me gusto el tipo de formato más organizado

campo	Descripción
ID del incidente	INC-2026-001
Fecha y hora de detención	2026/02/02 14:25 UTC
Analista responsable	Divier Jácamo Á
Categoría de incidente	Filtración de datos y acceso no autorizado
Nivel de sensibilidad	Datos sensibles (Salud)
Origen del incidente	IP externa con falla de proveedor de nube
Descripcion Tecnica	BD SQL comprometida
Impacto a clientes	Expedientes en riesgo
Acciones de contención	Se han revocado credenciales se ha apagado la instancia y se aplicó WAF
Estado de notificación	Se envió correo a pacientes y se ha comunicado a la PRODHAB
Estado de cierre	En investigación